

SecureOrg Inc.

PCI DSS Compliance Framework

Change Control Policy

Document Reference:	CCP-004
Version:	1.5
Effective Date:	April 14, 2026
Document Owner:	Chief Technology Officer
Classification:	CONFIDENTIAL
Review Cycle:	Annual
Framework:	PCI DSS v4.0

This document contains confidential and proprietary information. Unauthorized disclosure is prohibited.

1. Purpose and Scope

1.1 Purpose

This Change Control Policy establishes the governance framework for managing changes to IT systems, infrastructure, and applications within SecureOrg Inc., with emphasis on protecting the integrity and security of the cardholder data environment (CDE). The Policy ensures that all changes are assessed for security impact, authorized, tested, and documented in compliance with PCI DSS v4.0 Requirements 6.5 and 12.3.

1.2 Scope

This Policy applies to all changes to hardware, software, network configurations, operating systems, applications, security controls, and data flows within the CDE and systems connected to the CDE. Emergency changes, standard (pre-approved) changes, and normal changes are all within scope.

2. Change Management Principles

2.1 Core Principles

- No Unauthorized Changes: No changes to CDE systems shall be implemented without formal authorization through this process
- Security Impact Assessment: All changes shall undergo a security impact assessment before implementation
- Testing Requirements: Changes shall be tested in a non-production environment before production deployment
- Rollback Planning: A rollback plan shall be prepared for all changes before implementation
- Documentation: All changes shall be documented with sufficient detail to allow reconstruction of what was changed, when, by whom, and why
- Separation: Developers shall not implement changes directly to production environments

2.2 Change Categories

Emergency	Critical security patch or outage response	CISO + CTO (verbal, documented post-facto)	Immediate
Standard	Pre-approved low-risk routine changes	Change Manager	None (within schedule)
Normal – Minor	Low complexity, well-understood change	Change Advisory Board (CAB)	5 business days
Normal – Major	Significant or high-risk change	CAB + CISO (for CDE changes)	10 business days
Normal – Significant	Infrastructure redesign or new system deployment	CAB + Executive Sponsor	15+ business days

3. Change Request Process

3.1 Change Request Submission

All change requests must be submitted through the IT Service Management (ITSM) system and include:

- Description of the change and business justification
- Systems and components affected, including CDE scope determination
- Security impact assessment completed by the requester
- Implementation plan with step-by-step procedures

- Test plan and evidence of pre-production testing
- Rollback plan with rollback triggers and procedures
- Scheduled implementation window and expected downtime
- Communication plan for affected stakeholders

3.2 Security Impact Assessment

For all changes affecting CDE systems, a formal security impact assessment must address:

- Impact on PCI DSS compliance posture
- New attack surface or threat vectors introduced
- Changes to data flows involving CHD
- Impact on existing security controls (firewalls, IDS, logging)
- Network segmentation changes
- Authentication and access control implications

3.3 Change Advisory Board (CAB)

The CAB reviews and approves normal changes. CAB membership includes:

- Change Manager (CAB Chair)
- Information Security representative
- System/Application Owner
- Operations representative
- Business stakeholder representative
- CISO (mandatory for CDE changes)

The CAB meets weekly for scheduled changes. Emergency changes bypass the CAB but require post-implementation review at the next CAB meeting.

4. Pre-Implementation Requirements

4.1 Testing Requirements

All changes to CDE systems must be tested in a dedicated non-production environment that mirrors the production CDE configuration. Testing must include:

- Functional testing confirming the change achieves its intended objective

- Security testing including vulnerability scanning of modified components
- Regression testing confirming existing functionality is not impaired
- Integration testing confirming the change does not break system interactions
- Performance testing for changes with potential capacity impact

4.2 Code Review

Changes to custom code and applications in the CDE require code review before deployment:

- All code changes must be reviewed by a developer other than the author
- Code reviews must verify adherence to the Secure Development Policy (SDP-010)
- Automated static analysis security testing (SAST) must be completed and findings addressed
- Critical or high severity findings must be remediated before production deployment

4.3 Backup Verification

Before implementing significant changes to CDE systems, the change implementer must:

- Confirm current backup of the system exists and is verified as restorable
- For database changes, create a pre-change snapshot or export
- Document the backup location and restoration procedure in the change record

5. Implementation and Post-Implementation

5.1 Implementation Controls

During change implementation:

- Changes must be implemented exactly as documented in the approved change request
- The change implementer must not be the same individual who approved the change (for CDE changes)
- A separate approver must verify and confirm the implementation before the change window closes
- Any deviations from the approved plan must be reported to the Change Manager immediately
- Implementation activities must be logged in the change record in real-time

5.2 Post-Implementation Verification

After each change to the CDE:

- Confirm all security controls (firewalls, IDS/IPS, logging) are functioning as expected
- Verify network segmentation remains intact
- Confirm the change achieves its intended purpose
- Check audit logs are capturing expected events
- Update the system configuration documentation and asset inventory
- Close the change record with implementation details and confirmation

5.3 Emergency Change Post-Review

Emergency changes bypass the full pre-approval process but must be reviewed at the next CAB meeting. The post-review shall:

- Confirm the emergency was genuine and the change was appropriate
- Verify security controls were not compromised during emergency implementation
- Document lessons learned and identify permanent solutions where applicable
- Determine whether the emergency change needs to be reversed or made permanent

6. Change Records and Audit Trail

6.1 Record Requirements

Change records constitute compliance evidence for PCI DSS assessments. All change records must be retained for a minimum of 12 months and must capture:

- Unique change reference number and category
- Description, justification, and affected systems
- Security impact assessment results
- Approval chain with names, roles, and timestamps
- Test results and pre-production evidence
- Implementation log with timestamps and technician identification
- Post-implementation verification results
- Final status (successful, failed, rolled back)

6.2 Unauthorized Change Detection

Unauthorized changes are a critical security risk and potential indicator of compromise. Controls to detect unauthorized changes include:

- File Integrity Monitoring (FIM) on all CDE systems (PCI DSS Requirement 11.5)
- Daily comparison of actual system configurations against approved baselines
- Automated alerting on configuration deviations
- Review of all FIM alerts within 24 hours
- Unauthorized changes treated as potential security incidents until investigated

7. Patch Management

7.1 Patch Classification and Timelines

Critical	9.0 – 10.0	Within 15 days	All systems; CDE prioritized
High	7.0 – 8.9	Within 30 days	All systems
Medium	4.0 – 6.9	Within 90 days	All systems
Low	0.1 – 3.9	Next scheduled maintenance	Risk-based assessment

7.2 Patch Process

The patch management process follows the standard change control process with the following additions:

- Patches must be tested in a non-production environment before deployment
- Critical patches that cannot be applied within the required timeline require a formal risk acceptance from the CISO
- Compensating controls must be documented for any delayed critical patches

8. Revision History

1.0	Jan 15, 2024	Initial release	CTO Office
1.3	Sep 3, 2024	Updated patch timelines; emergency change process	Security Team

1.5	Apr 14, 2026	Annual review; code review requirements; unauthorized change detection	CTO/CISO
-----	--------------	--	----------